

Ritual Security Policy Packet

Company: Ritual

Prepared by: Nicholas Gardner, Founder

Effective Date: 2026-03-18

Document Version: 1.0

Overview

This document summarizes Ritual's current information security, access control, and incident response practices.

Ritual is a behavior and personal data product that connects user-selected data sources, including wearable, health, and financial integrations, in order to help users track and understand behavioral patterns over time. For Plaid-backed spending, Ritual's intended use is limited to generating daily spending totals for a user's habit data rather than operating a general-purpose transaction analysis or budgeting product.

Ritual's security approach is designed to be practical, documented, and operational for a small but production-oriented software company. It focuses on least-privilege access, server-side credential handling, encrypted storage of sensitive integration tokens in production, monitored backend services, and documented response procedures for security events.

1. Information Security Policy

Purpose

Ritual maintains an Information Security Policy to identify, mitigate, and monitor information security risks relevant to the business, product, and user data processed by Ritual.

This policy applies to Ritual's dashboard, backend APIs, desktop application, iOS companion application, supporting infrastructure, and third-party integrations.

Security Principles

Ritual's security program is guided by the following principles:

- protect the confidentiality of user data and integration credentials
- preserve the integrity of user records, sync pipelines, and analytics

- minimize the collection and retention of sensitive data
- restrict access to systems and data based on legitimate business need
- monitor systems for failures, broken credentials, and other security-relevant events
- respond to incidents promptly and document remediation actions

Governance and Risk Management

Security oversight is owned by Nicholas Gardner, Founder of Ritual. Security responsibilities include maintaining security policies, reviewing material architecture or vendor changes, controlling production access, and coordinating incident response.

Ritual performs security review when:

- enabling a new high-sensitivity integration such as Plaid
- introducing new credential storage or sync flows
- making material changes to authentication, backend data handling, or third-party access
- responding to security incidents or identified vulnerabilities

Access Control

Ritual limits access to production systems, operational tools, and user data to authorized persons with a legitimate business need.

Key requirements:

- production access is granted on a least-privilege basis
- secrets are stored outside source control
- access is removed when no longer required
- shared credentials are avoided where practical
- protected backend routes require authenticated bearer tokens

Ritual uses Clerk for end-user authentication, and backend APIs validate authentication tokens server-side before granting access to protected resources.

Credential and Secret Protection

Ritual treats integration credentials, device secrets, and authentication tokens as sensitive data.

Security controls include:

- server-side handling of third-party credentials whenever possible
- encrypted storage of sensitive integration tokens in production using an application-managed encryption key

- separation of encryption keys from stored application data
- avoidance of storing plaintext secrets in code, logs, or documentation

For Plaid specifically, access tokens are intended to remain on the backend and are not intentionally exposed directly to browser or desktop clients.

Data Minimization

Ritual limits data collection and use to what is necessary to provide the product.

Examples:

- authentication data is used only for account access and session validation
- wearable and health data are used only for the sync and analytics functionality selected by the user
- Plaid-backed spending is scoped to generating daily spending totals for a user's Ritual habit data rather than operating a broad transaction analysis product

Secure Development and Operations

Ritual incorporates security into development through code review, scoped releases, and validation of sensitive flows before deployment.

Current operational controls include:

- protected backend APIs that require authenticated bearer tokens
 - encryption support for stored integration tokens in production
 - server-side Plaid token handling and reconnect flows
 - rate limiting and CORS controls in the backend
 - backend health checks and application logging
 - platform keychain storage for iOS companion credentials
-

2. Incident Response Plan

Purpose

Ritual maintains an Incident Response Plan defining how suspected or confirmed information security incidents are identified, contained, investigated, remediated, and documented.

Scope

This plan applies to incidents involving:

- unauthorized access to Ritual systems or user data
- exposure or misuse of authentication or integration credentials
- compromise or suspected compromise of production infrastructure
- material failures affecting the confidentiality, integrity, or availability of user data
- suspicious activity involving Plaid, wearable, or other connected integrations

Ownership

Nicholas Gardner, Founder of Ritual, is responsible for incident coordination, containment decisions, remediation oversight, communications, and documentation.

Response Process

Ritual handles material security incidents through the following process:

1. Identify and validate the event.
2. Contain the issue by restricting access, disabling affected integrations or endpoints, or rotating credentials as appropriate.
3. Assess scope, affected systems, affected data, and whether the incident is ongoing.
4. Remediate the root cause and restore service safely.
5. Document the incident, actions taken, and follow-up improvements.

Where required by law, contract, or platform obligations, Ritual will notify affected parties or relevant vendors.

3. Access Control Policy

Principle

Ritual grants access based on least privilege and legitimate business need. Access is limited to the minimum required to perform a role or task.

Scope

This policy applies to:

- production infrastructure and hosted services
- backend administration and operational tooling
- source code repositories
- databases and analytics systems

- authentication, integration, and encryption secrets
- user data and support access

Requirements

Ritual requires that:

- access be granted only to authorized individuals
- production access be limited to those who need it for engineering, operations, or support
- secrets not be stored in source control
- unique credentials be used where practical
- access be revoked when no longer needed

Sensitive Systems

Higher-sensitivity systems include:

- authentication systems
- production databases
- encryption keys
- integration credential stores
- financial and health-related data flows

Access to these systems is more tightly restricted than general development access.

End-User and Administrative Controls

Ritual uses Clerk for end-user authentication. Backend APIs validate authenticated bearer tokens before permitting access to protected user resources.

Administrative access is limited to authorized operators and is expected to use secure authentication methods and follow least-privilege principles.

4. Operationalization in Ritual

Ritual's documented security controls are reflected in its current architecture and codebase, including:

- Clerk-based authentication with server-side JWT verification
- encrypted storage support for integration tokens via `TOKEN_ENCRYPTION_KEY`
- server-side handling of Plaid access tokens

- Plaid reconnect and webhook handling for broken or changed Items
- CORS restrictions and API rate limiting
- backend health checks and logging
- iOS Keychain storage for mobile companion credentials

Representative implementation references:

- `apps/backend/services/auth_service.py`
 - `apps/backend/services/token_crypto.py`
 - `apps/backend/services/plaid_service.py`
 - `apps/backend/api/financial.py`
 - `apps/backend/main.py`
 - `apps/ios-companion/Sources/RitualCompanion/Services/RitualAPIClient.swift`
-

5. Approval

Prepared by: Nicholas Gardner

Title: Founder

Company: Ritual

Date: 2026-03-18